

Web Investigation

Exercise: 1.2 | Cross Site Scripting Activity detected

Objectives:

The primary objective is to conduct a thorough investigation into a suspected Cross Site Scripting Incident with the goal of identifying the source, scope, and impact of the attack.

Incident Details:

Investigate the suspicious Cross Site Scripting activity detected by the security monitoring systems. Investigate the web logs to identify the targeted IP, source, and potential impact.

Targeted URL:

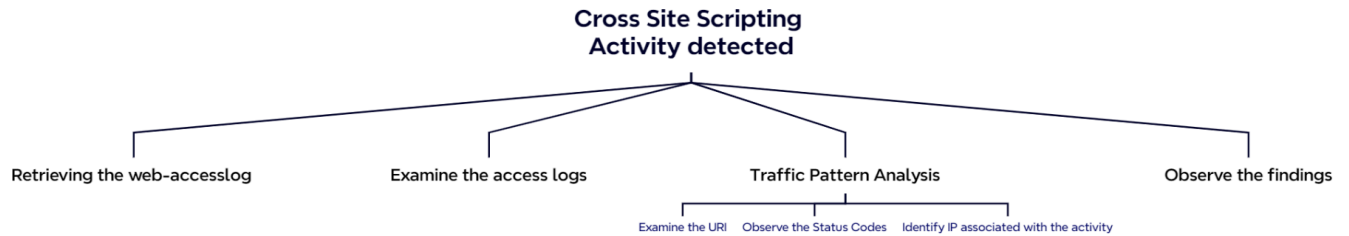
http://192.168.117.190/prod/vulnerabilities/xss_r/

About XSS:

XSS is a type of web-based security vulnerability that occurs when an attacker is able to manipulate or inject malicious Java Script commands into a query. This can happen when input from an application, such as a web form or URL parameter.



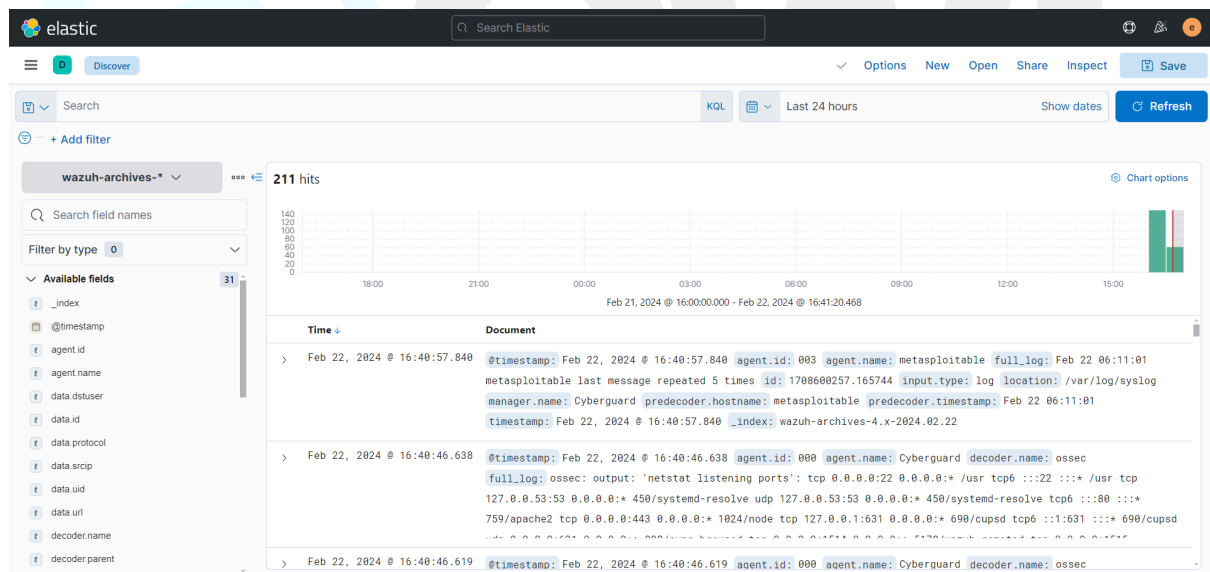
Investigation Mindmap:



Step:01

The first step of the investigation begins by analysing the web server logs. In our Blue Team Infrastructure, as we integrated the web log with our SIEM Wazuh Solutions

Open the SIEM Console and navigate to the Analytics → Discover section



The screenshot shows the Elastic SIEM Console interface. The top navigation bar includes the Elastic logo, a search bar, and various icons. The main section is titled 'Discover' and shows a search for 'wazuh-archives-*' with 211 hits. The left sidebar lists available fields such as @timestamp, agent.id, agent.name, data.dsluser, data.id, data.protocol, data.scrip, data.uid, data.url, decoder.name, and decoder.parent. The main content area displays a timeline view of the search results, showing three hits from February 22, 2024. The first hit is at 16:40:57.840, the second at 16:40:46.638, and the third at 16:40:46.619. Each hit shows the @timestamp, agent.id, agent.name, and a full_log entry.

Note: Make sure that your are under **wazuh-archives** index

Step:03

Investigating XSS involves careful steps to ensure security and determine the nature and potential threats associated with the web logs.

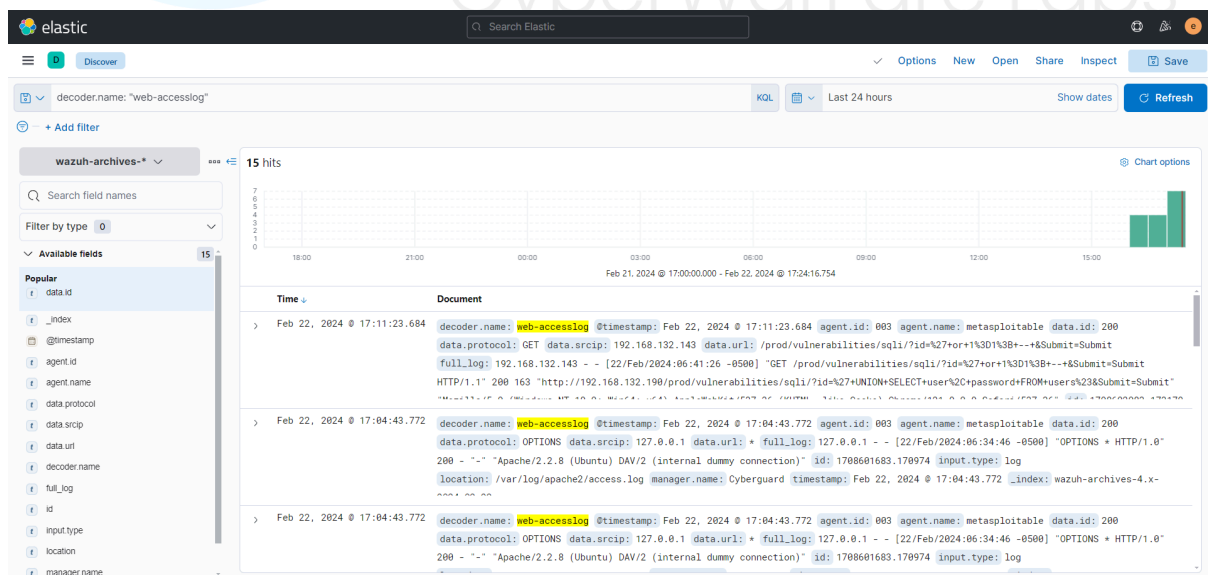
1. Retrieving the web-accesslog : decoder
2. Examine the access logs
3. Traffic Pattern Analysis
 - a. Examine the URI
 - b. Observe the Status Codes
 - c. Identify IP associated with the activity
4. Observe the findings

Retrieving the web-accesslog

Identifying and collecting the web access log allows us to extract certain logs for additional investigation.

Use the following command to obtain the web-access log.

```
Unset
decoder.name: "web-accesslog"
```



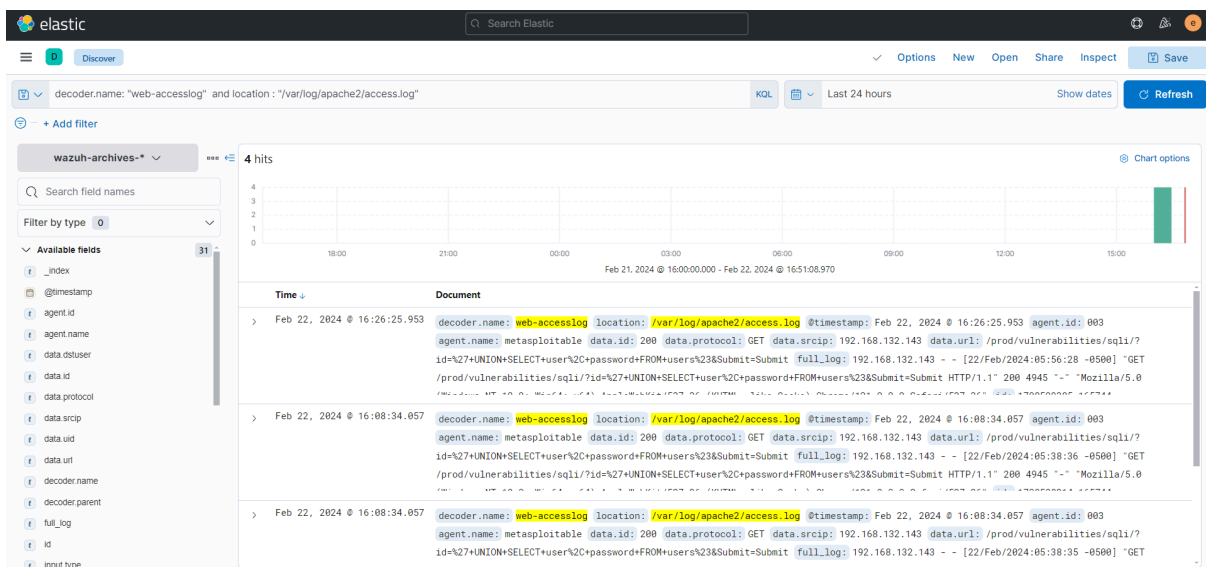
Decoders are the key components which are responsible for parsing raw logs into a structured format that can be easily analysed and understood by the system.

Examine the access logs

In general web server logs contain valuable information about incoming requests, errors, and server activities. It is recommended to check the access logs which record every request made to the server.

Unset

```
decoder.name: "web-accesslog" and location : "/var/log/apache2/access.log"
```



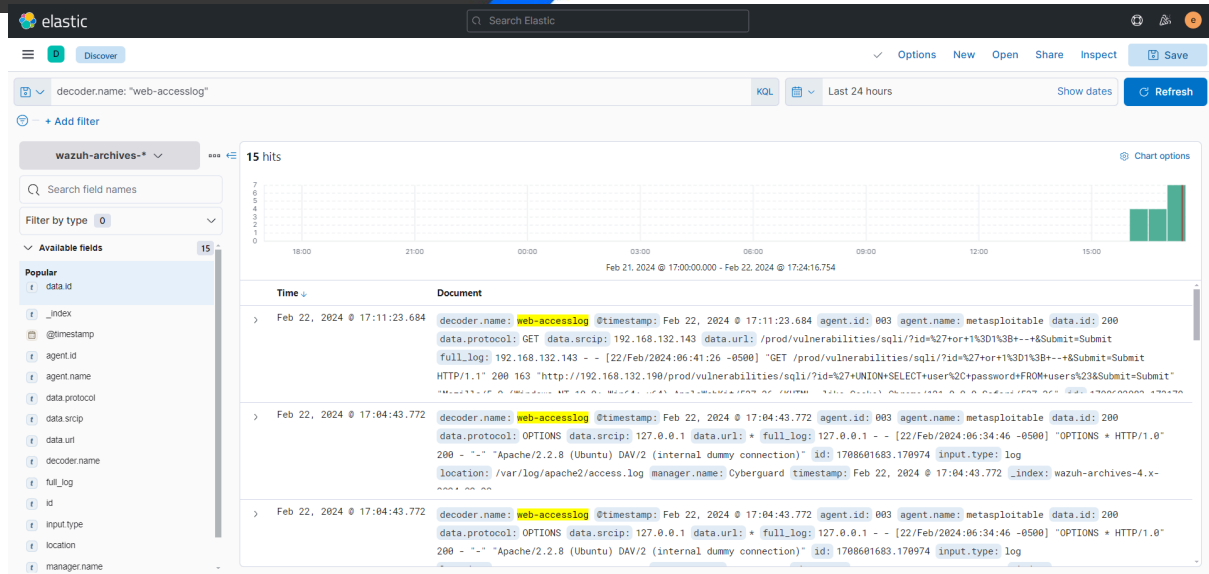
Note: Access logs provide details like IP addresses, requested files, status codes, etc.

Examine the URL

The next step is to observe the URL & URI request observed over the detected URL path, this helps us to identify the requests which are trying to be accessed by the attacker. Execute the below command and observe the findings.

Unset

```
decoder.name: "web-accesslog" and location : "/var/log/apache2/access.log"
and data.url : /prod/vulnerabilities/xss_r/*
```



For better understanding, it is recommended to use the visualise option.

Top values of data.url	Count of records
<code>/prod/vulnerabilities/xss_r/?name=%3Cimg+src%3Dx+onerror%3D%22alert%28document.cookie%29%22...</code>	3
<code>/prod/vulnerabilities/xss_r/x</code>	3
<code>/prod/vulnerabilities/xss_r/</code>	2

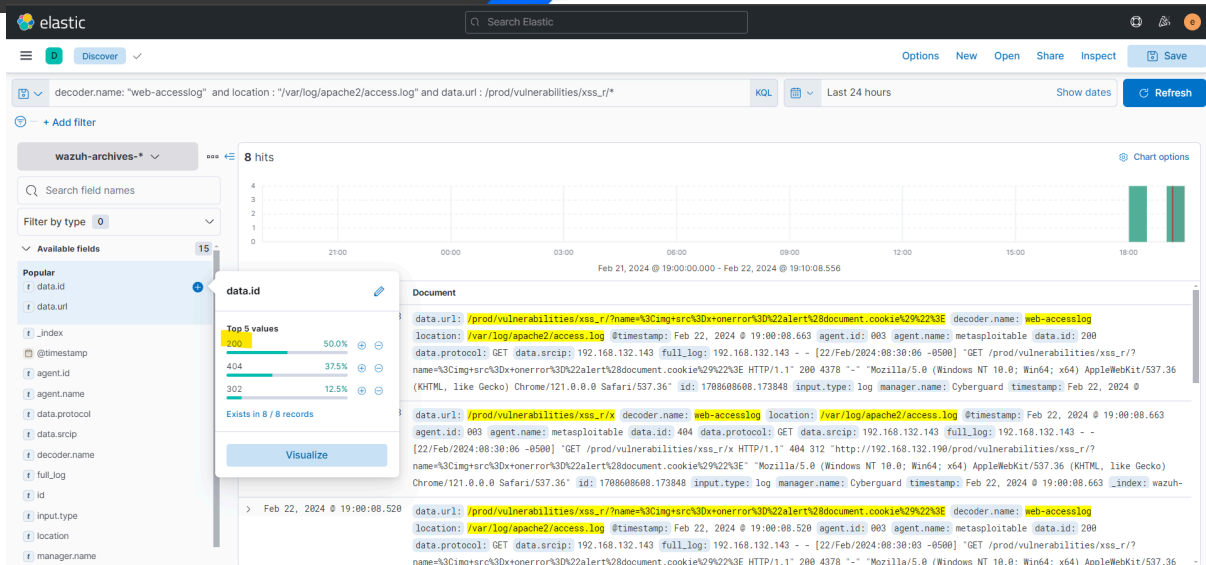
As per the above result, we observed multiple XSS commands over the web url request. In general, it's not considered as a normal activity when we observe a Java Script command over the URL/URI requests

Examine the Status Codes

To validate or identify the suspicious activity it is recommended to check HTTP status codes of the observed logs. Execute the below query and observe the result.

Unset

```
decoder.name: "web-accesslog" and location : "/var/log/apache2/access.log"
and data.url : /prod/vulnerabilities/xss_r/* and data.id: *
```



As per the observation we found multiple requests with a status code 200, 404, 302.

Note: HTTP 200 generally indicates a successful HTTP request. This particular request appears when a client sends a GET request to the server, and the server successfully retrieves the requested resource, it responds with a status code of 200.

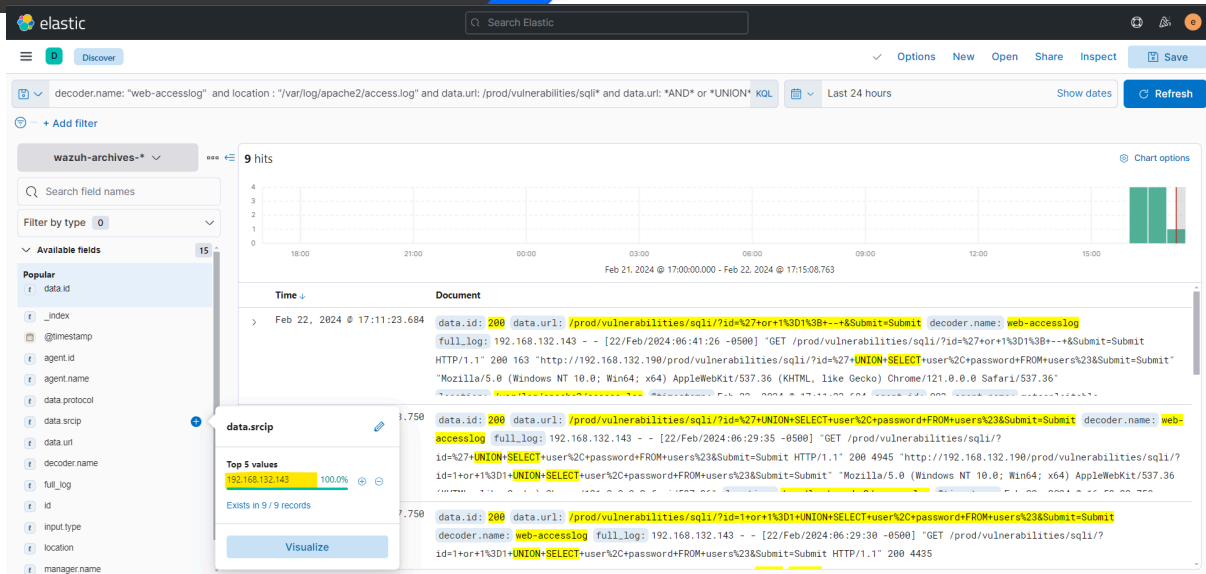
In case of XSS exploit this specific pattern will be observed because the attacker will try executing multiple Java Script commands over the web URL.

Identify IP associated with the activity

After Identifying the attack pattern it's recommended to look for IP addresses associated with the enumeration activity. Execute the below command and observe the finding.

Unset

```
decoder.name: "web-accesslog" and location: "/var/log/apache2/access.log"
and data.url: /prod/vulnerabilities/xss_r/* and data.id: "200" and
data.srcip: *
```



In real case scenarios you might observe lot more IP activity its been categories based on their legitimacy, behaviour and its reputation

Conclusion

The thorough examination of the incident has allowed you to understand the sequence of events leading up to the occurrence, identifying areas for improvement in processes and procedures.

Thank You!

Hope you have learnt a lot after practically completing
Blue Team Fundamentals Exercise.

If you like the investigation & the lab scenario,
feel free to tag us & share your achievement / progress
on social media platforms :)

For Enterprise Red Team / Blue Team / Purple Team
Cyber Range Labs / Training please email :
support@cyberwarfare.live

To know more visit at : <https://cyberwarfare.live>